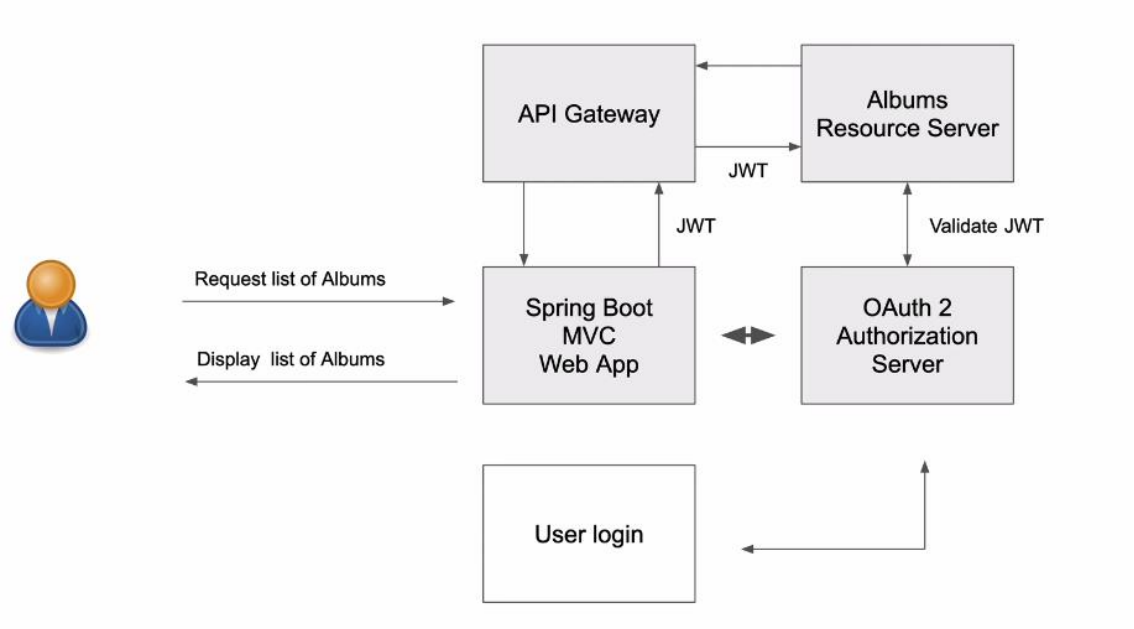
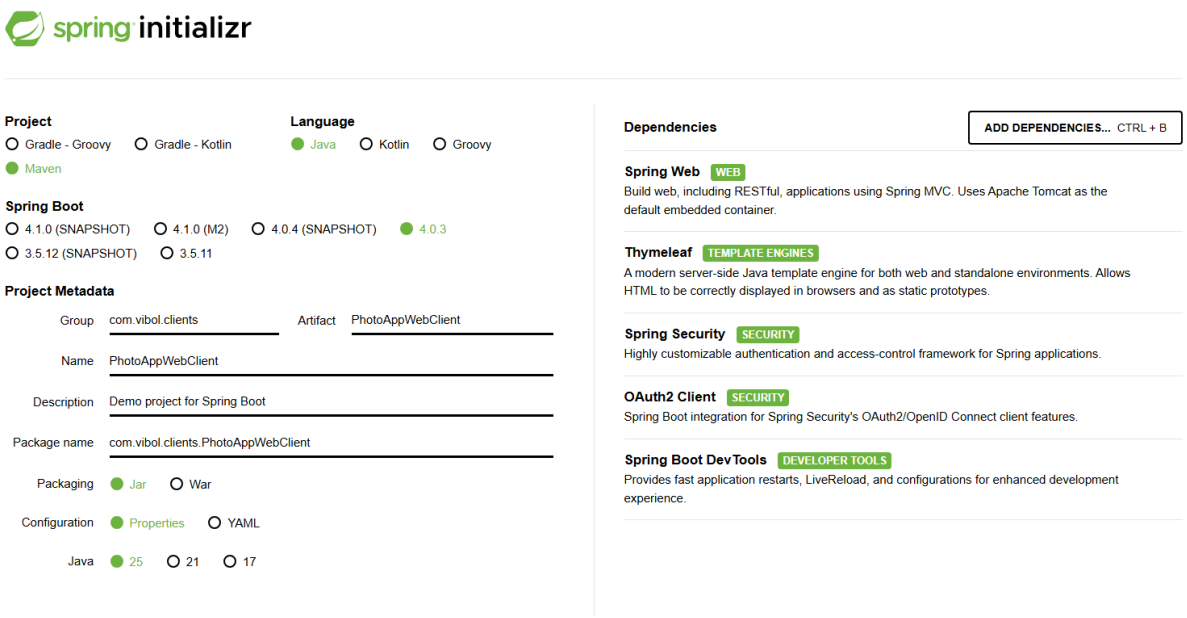
OAuth In MVC Web App

យើងមាន Website មួយពេលគេចង់ចូលទៅកាន់ Url យើងចឹង ដំបូងឡើយយើងអោយគេ Log in ចូលសិន បើមានសិទ្ធអាចអោយចូលមើបាន



1- Create spring boot



- Dependency

```xml
<?xml version="1.0" encoding="UTF-8"?>
<project xmlns="http://maven.apache.org/POM/4.0.0"
         xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
         xsi:schemaLocation="http://maven.apache.org/POM/4.0.0 https://maven.apache.org/xsd/maven-4.0.0.xsd">
  <modelVersion>4.0.0</modelVersion>

  <parent>
    <groupId>org.springframework.boot</groupId>
    <artifactId>spring-boot-starter-parent</artifactId>
    <version>4.0.3</version>
    <relativePath/>
  </parent>

  <groupId>com.vibol.clients</groupId>
  <artifactId>PhotoAppWebClient</artifactId>
  <version>0.0.1-SNAPSHOT</version>
  <name>PhotoAppWebClient</name>
  <description>Demo project for Spring Boot</description>

  <properties>
    <java.version>25</java.version>
  </properties>

  <dependencies>
    <!-- MVC + Thymeleaf -->
    <dependency>
      <groupId>org.springframework.boot</groupId>
      <artifactId>spring-boot-starter-webmvc</artifactId>
    </dependency>
    <dependency>
      <groupId>org.springframework.boot</groupId>
      <artifactId>spring-boot-starter-thymeleaf</artifactId>
    </dependency>

    <!-- Security + OAuth2 Login (Keycloak redirect) -->
    <dependency>
      <groupId>org.springframework.boot</groupId>
      <artifactId>spring-boot-starter-security</artifactId>
    </dependency>
    <dependency>
      <groupId>org.springframework.boot</groupId>
      <artifactId>spring-boot-starter-oauth2-client</artifactId>
    </dependency>

    <!-- Devtools -->
    <dependency>
      <groupId>org.springframework.boot</groupId>
      <artifactId>spring-boot-devtools</artifactId>
      <scope>runtime</scope>
      <optional>true</optional>
    </dependency>

    <!-- Configuration metadata generation -->
    <dependency>
      <groupId>org.springframework.boot</groupId>
      <artifactId>spring-boot-configuration-processor</artifactId>
      <optional>true</optional>
    </dependency>

    <!-- Tests -->
    <dependency>
      <groupId>org.springframework.boot</groupId>
      <artifactId>spring-boot-starter-webmvc-test</artifactId>
      <scope>test</scope>
    </dependency>
    <dependency>
      <groupId>org.springframework.boot</groupId>
      <artifactId>spring-boot-starter-thymeleaf-test</artifactId>
      <scope>test</scope>
    </dependency>
  </dependencies>

  <build>
    <plugins>
      <plugin>
        <groupId>org.springframework.boot</groupId>
        <artifactId>spring-boot-maven-plugin</artifactId>
      </plugin>
    </plugins>
  </build>

</project>
```

- Controller :/albums

```
package com.vibol.clients.PhotoAppWebClient.controller;

import java.util.Arrays;
import java.util.List;

import org.springframework.security.core.annotation.AuthenticationPrincipal;
import org.springframework.security.oauth2.core.oidc.OidcIdToken;
import org.springframework.security.oauth2.core.oidc.user.OidcUser;
import org.springframework.stereotype.Controller;
import org.springframework.ui.Model;
import org.springframework.web.bind.annotation.GetMapping;

import com.vibol.clients.PhotoAppWebClient.controller.response.AlbumRest;

@Controller
public class AlbumsController {

	@GetMapping("/albums")
	public String getAlbums(Model model, @AuthenticationPrincipal OidcUser principal) {

		System.out.println("Principal = " + principal);


		OidcIdToken idToken = principal.getIdToken();
		String idTokenValue = idToken.getTokenValue();

		System.out.println("idTokenValue = " + idTokenValue);

		AlbumRest album = new AlbumRest();

		album.setAlbumId("albumOne");
		album.setAlbumTitle("Album one title");
		album.setAlbumUrl("http://localhost:8082/album/1");

		AlbumRest album2 = new AlbumRest();

		album2.setAlbumId("albumTwo");
		album2.setAlbumTitle("Album two title");
		album2.setAlbumUrl("http://localhost:8082/album/2");

		/*
		// create list with two object album1 and album2
		List returnValue = Arrays.asList(album, album2);
		//disply to the model
		model.addAttribute("albums",returnValue);
		*/

		model.addAttribute("albums", Arrays.asList(album, album2));
		return "albums";
	}
}
```

Option 2: Install the missing Eclipse "Web" tools (WTP)

If you *really* want the "Web" category and HTML file wizard templates:

Install WTP

1. **Help → Eclipse Marketplace**
2. Search and install:
   - **Eclipse Web Developer Tools**
   - (or) **Eclipse Java EE Developer Tools**
   - (or) **Web Tools Platform (WTP)**

Restart STS.

After that, you should see things like:

- **File → New → Other → Web**
- HTML File wizard / Dynamic Web Project, etc.

> On some STS builds, the "Web" node only appears after WTP is installed.

- Create Template: Thymeleaf

Option 2: Install the missing Eclipse "Web" tools (WTP)

If you *really* want the "Web" category and HTML file wizard templates:

Install WTP

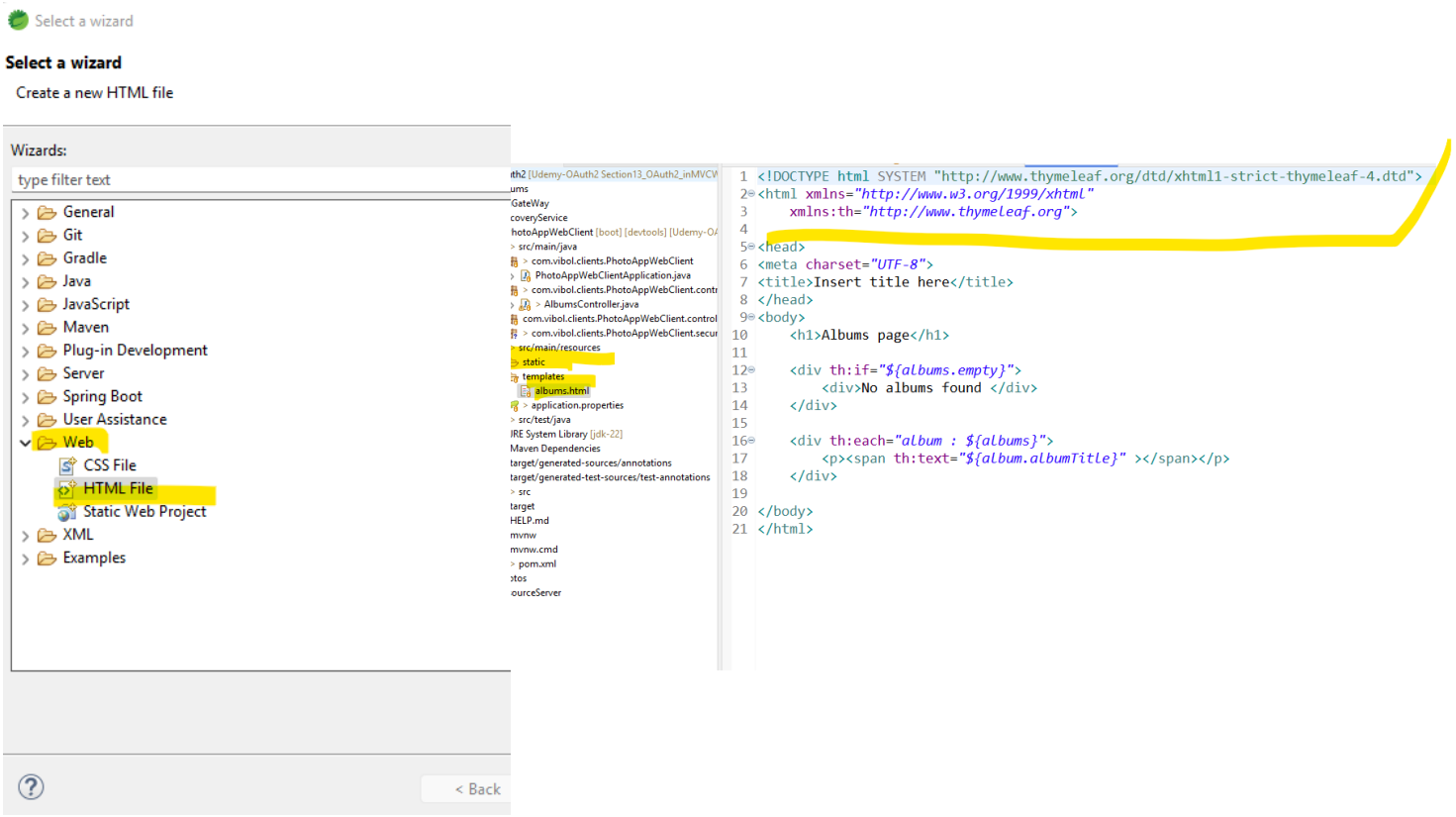
1. **Help → Eclipse Marketplace**
2. Search and install:
   - **Eclipse Web Developer Tools**
   - (or) **Eclipse Java EE Developer Tools**
   - (or) **Web Tools Platform (WTP)**

Restart STS.

After that, you should see things like:

- **File → New → Other → Web**
- HTML File wizard / Dynamic Web Project, etc.

> On some STS builds, the "Web" node only appears after WTP is installed.



```
<!DOCTYPE html SYSTEM "http://www.thymeleaf.org/dtd/xhtml1-strict-thymeleaf-4.dtd">
<html xmlns="http://www.w3.org/1999/xhtml"
        xmlns:th="http://www.thymeleaf.org">

<head>
<meta charset="UTF-8">
<title>Insert title here</title>
</head>
<body>
        <h1>Albums page</h1>

        <div th:if="${albums.empty}">
                <div>No albums found </div>
        </div>

        <div th:each="album : ${albums}">
                <p><span th:text="${album.albumTitle}" ></span></p>
        </div>

</body>
</html>
```

- Application.properties

```
spring.security.oauth2.client.registration.mywebclient.client-id=photo-app-webclient
spring.security.oauth2.client.registration.mywebclient.client-
secret=i27W6rABxAnvbnmwzebLFwJRKlElV12N
spring.security.oauth2.client.registration.mywebclient.scope=openid,profile,roles
spring.security.oauth2.client.registration.mywebclient.authorization-grant-type=authorization_code
spring.security.oauth2.client.registration.mywebclient.redirect-
uri=http://localhost:8087/login/oauth2/code/mywebclient

spring.security.oauth2.client.provider.mywebclient.authorization-
uri=http://localhost:8080/realms/mywebclient/protocol/openid-connect/auth
spring.security.oauth2.client.provider.mywebclient.token-
uri=http://localhost:8080/realms/mywebclient/protocol/openid-connect/token
spring.security.oauth2.client.provider.mywebclient.jwk-set-
uri=http://localhost:8080/realms/mywebclient/protocol/openid-connect/certs
spring.security.oauth2.client.provider.mywebclient.user-info-
uri=http://localhost:8080/realms/mywebclient/protocol/openid-connect/userinfo
spring.security.oauth2.client.provider.mywebclient.user-name-attribute=preferred_username
spring.security.oauth2.client.provider.mywebclient.issuer-uri=http://localhost:8080/realms/mywebclient
```

application.properties

```
spring.application.name=PhotoAppWebClient
server.port=8087

spring.security.oauth2.client.registration.mywebclient.client-id=photo-app-webclient
spring.security.oauth2.client.registration.mywebclient.client-secret=i27W6rABxAnvbnmwzebLFwJRKlElV12N
spring.security.oauth2.client.registration.mywebclient.scope=openid,profile,roles
spring.security.oauth2.client.registration.mywebclient.authorization-grant-type=authorization_code
spring.security.oauth2.client.registration.mywebclient.redirect-uri=http://localhost:8087/login/oauth2/code/mywebclient

spring.security.oauth2.client.provider.mywebclient.authorization-uri=http://localhost:8080/realms/mywebclient/protocol/openid-connect/auth
spring.security.oauth2.client.provider.mywebclient.token-uri=http://localhost:8080/realms/mywebclient/protocol/openid-connect/token
spring.security.oauth2.client.provider.mywebclient.jwk-set-uri=http://localhost:8080/realms/mywebclient/protocol/openid-connect/certs
spring.security.oauth2.client.provider.mywebclient.user-info-uri=http://localhost:8080/realms/mywebclient/protocol/openid-connect/userinfo
spring.security.oauth2.client.provider.mywebclient.user-name-attribute=preferred_username
spring.security.oauth2.client.provider.mywebclient.issuer-uri=http://localhost:8080/realms/mywebclient
```

Big picture: who is who?

registration.mywebclient = your app (the client)

This section tells Spring Security:

"When my app logs in with OAuth/OIDC, use these client credentials and these login settings."

Think: *client-id, secret, scopes, grant type, redirect URI.*

provider.mywebclient = the external Identity Provider (IdP)

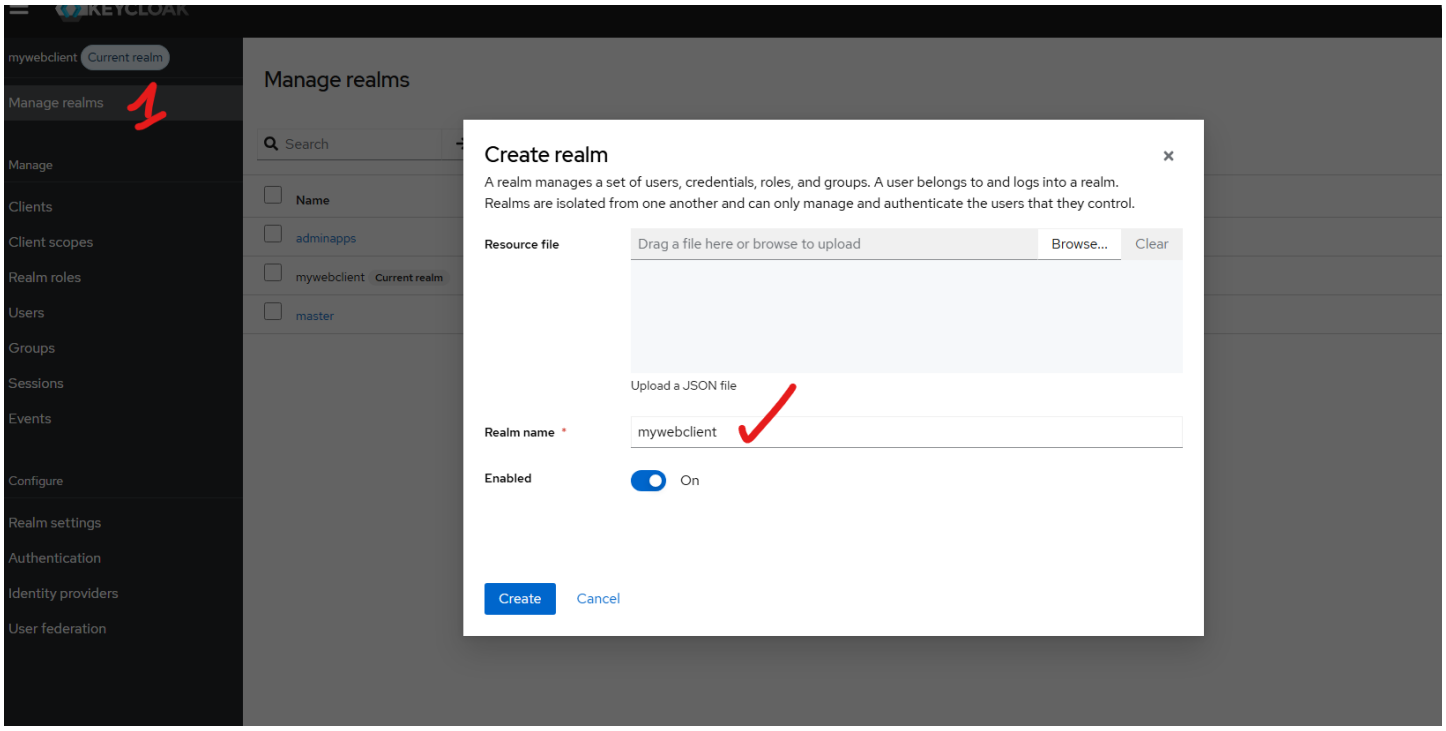
This section tells Spring Security:

"Here are the URLs of the Identity Provider (Keycloak realm) to talk to."

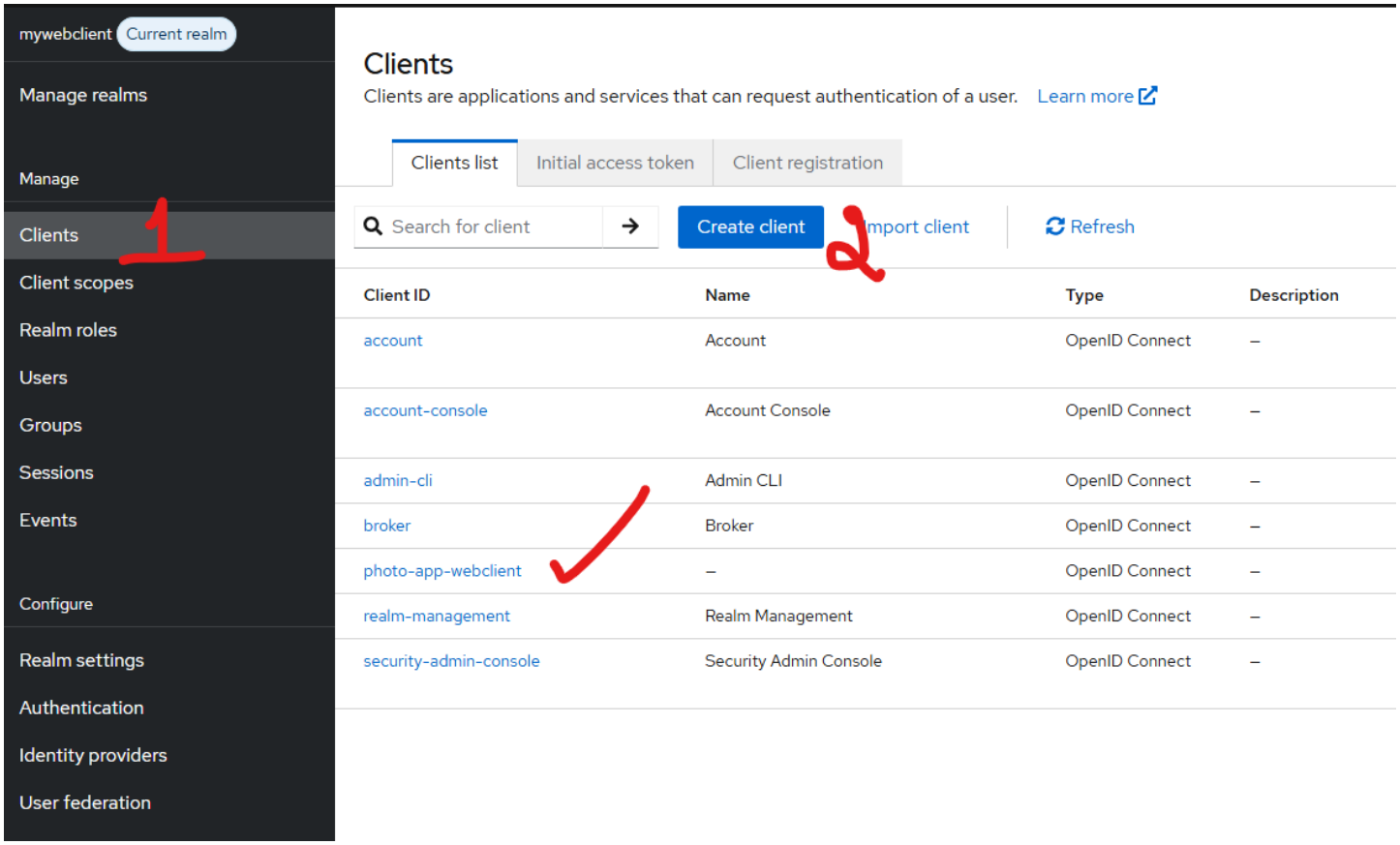
Think: *authorization endpoint, token endpoint, jwks endpoint, userinfo endpoint, issuer.*

Keyload Create Client

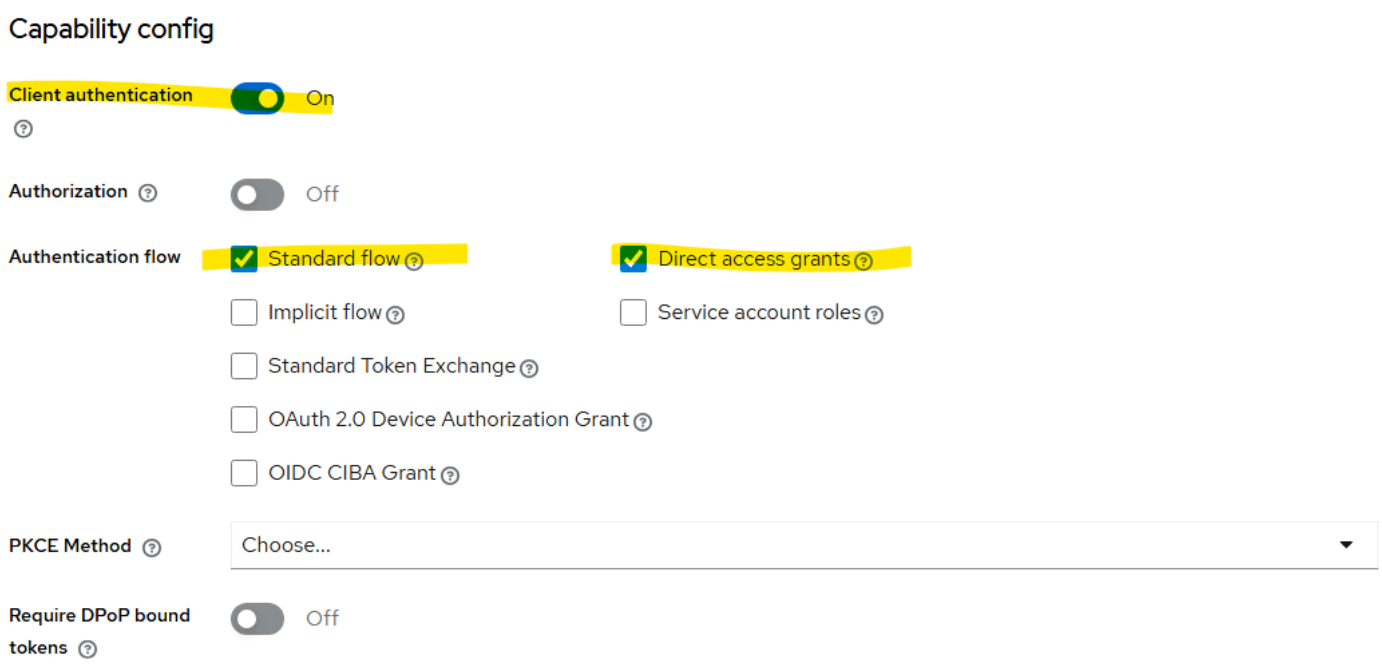
1-Create reamls



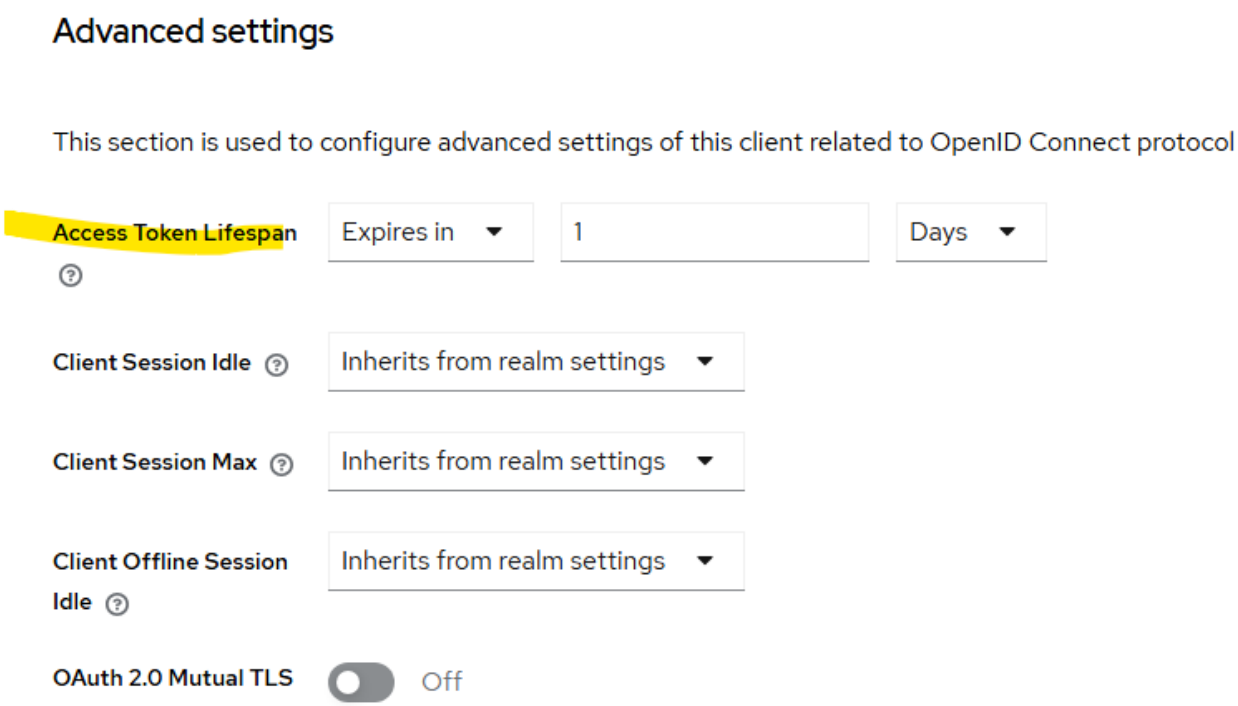
2-Create client



Setting in client:

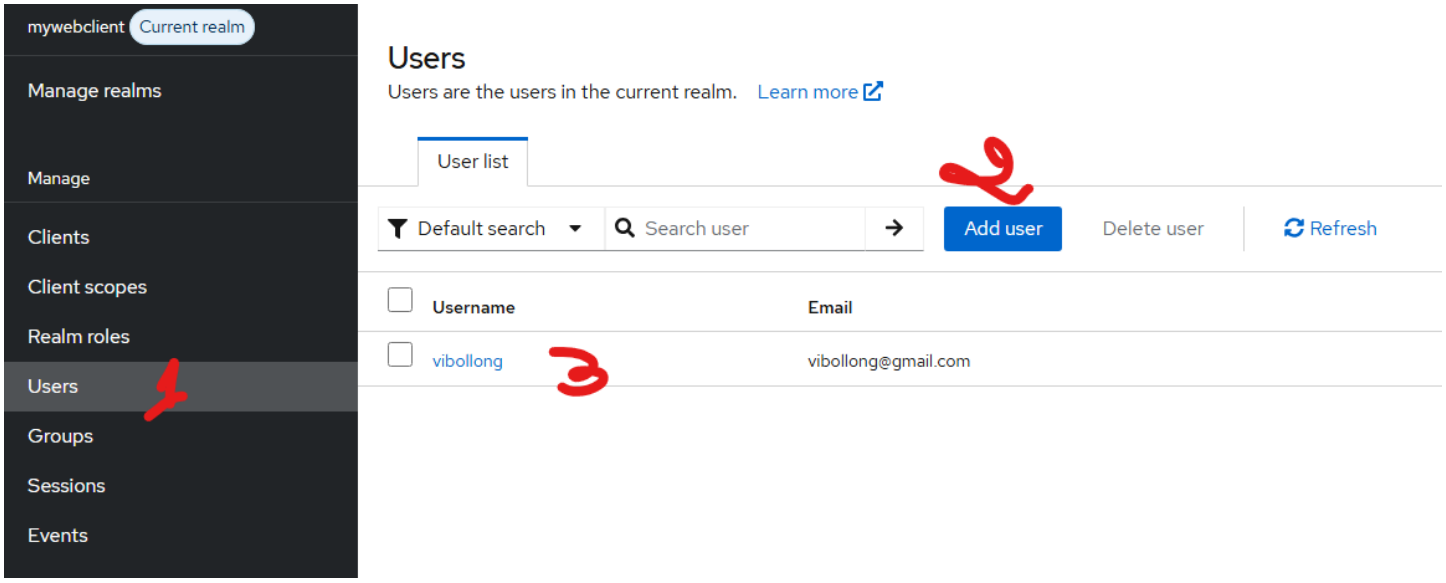


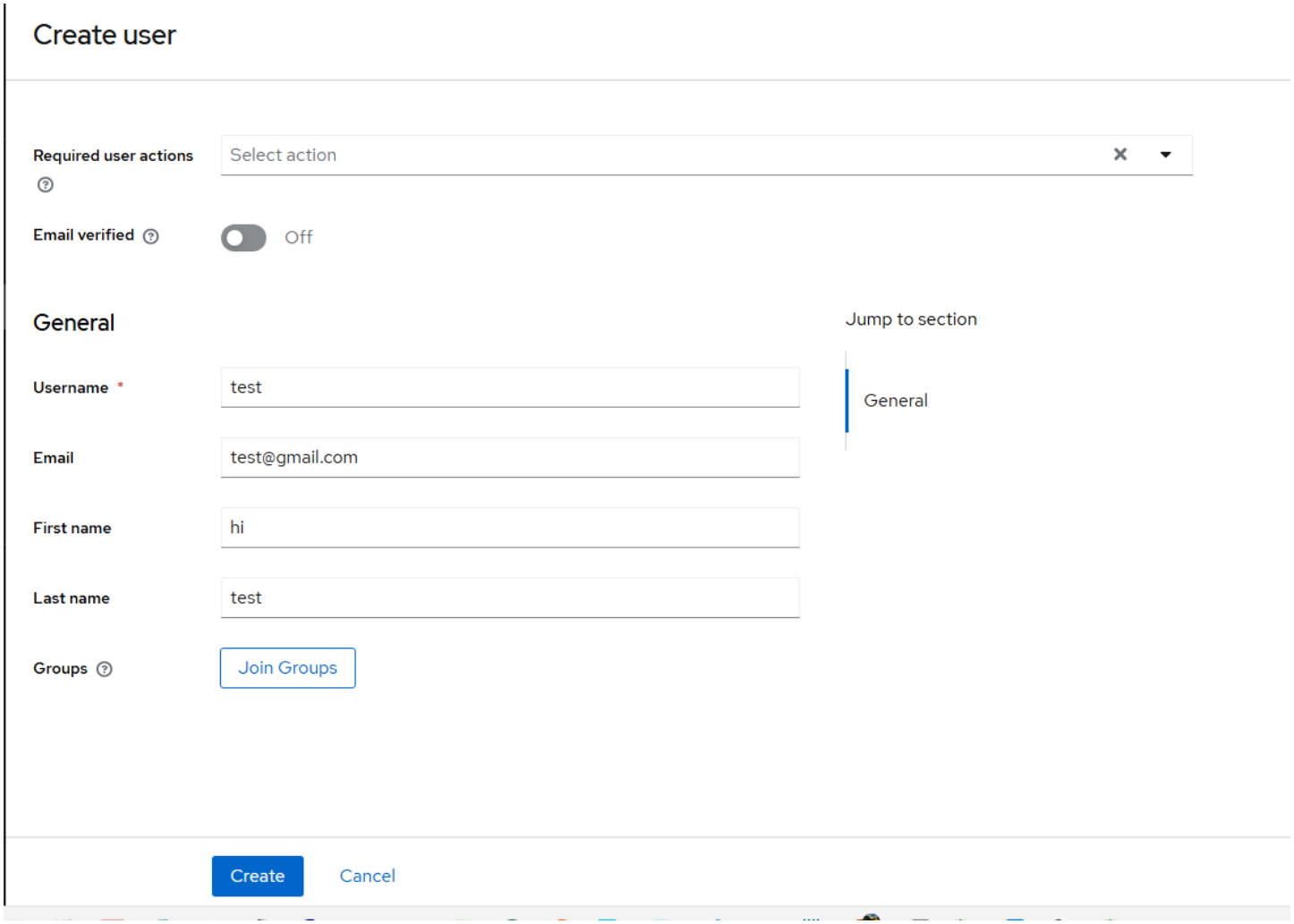
- Create standard login



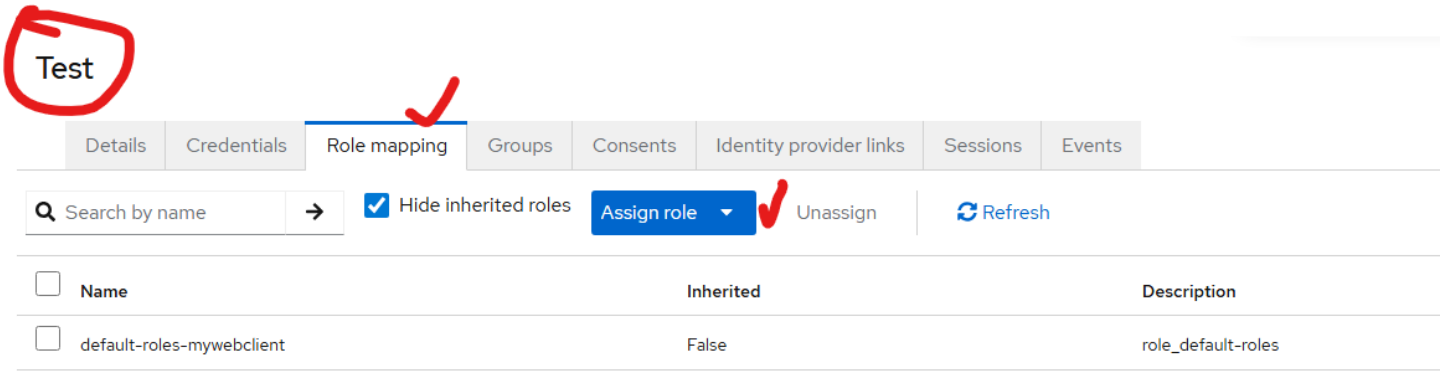
- Keep the Access Token longer

3-Create user

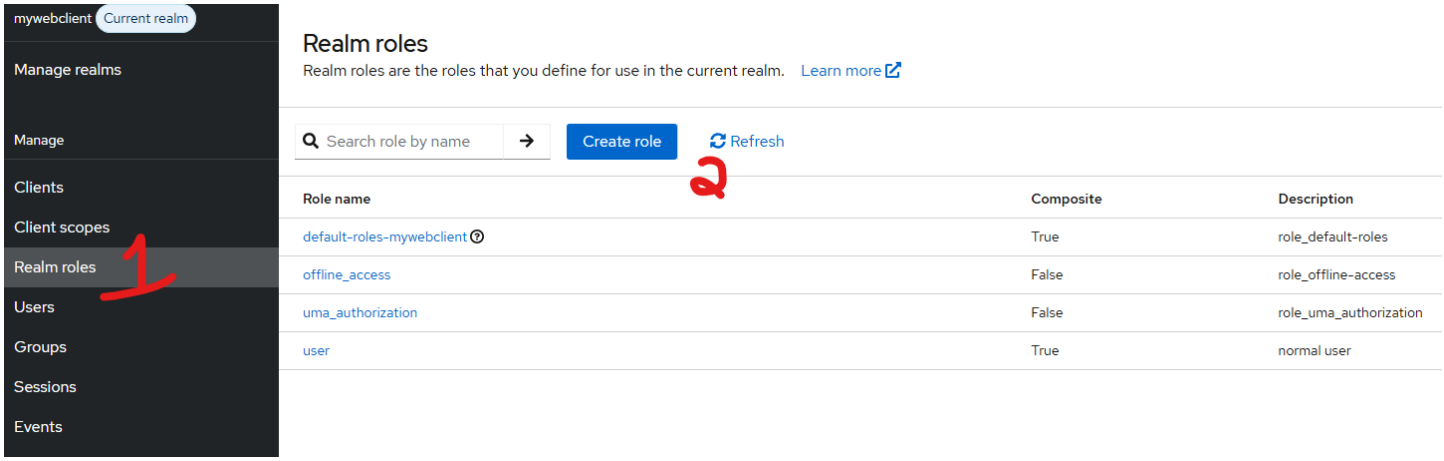


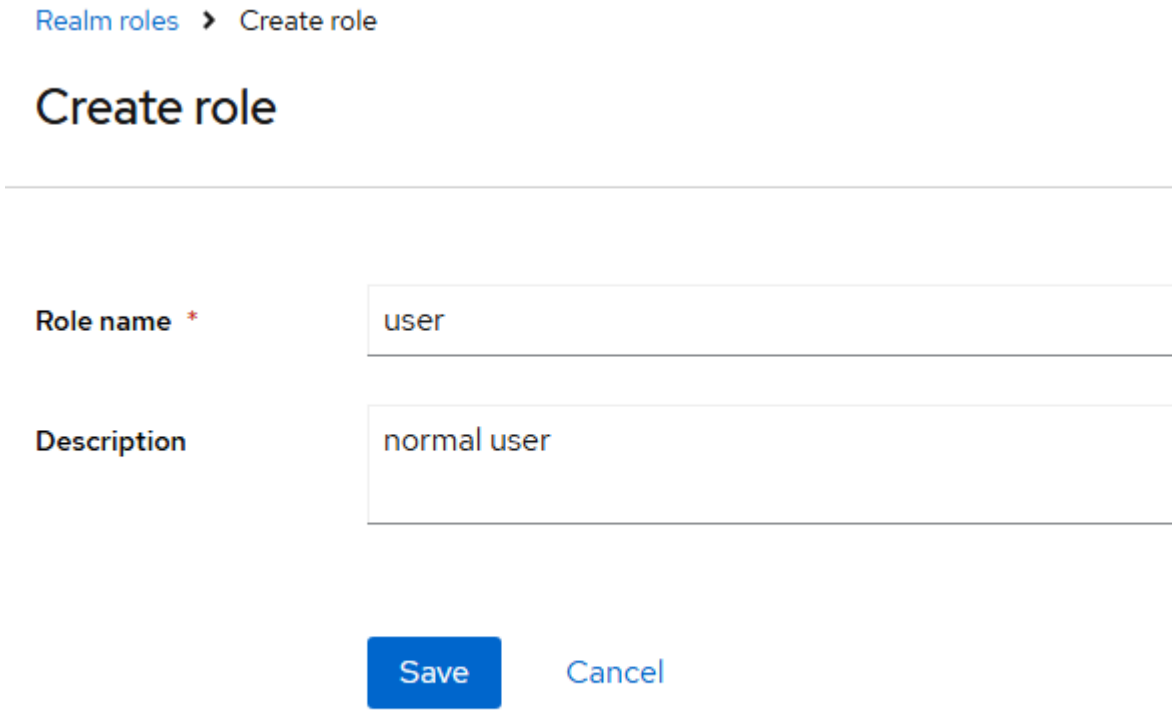


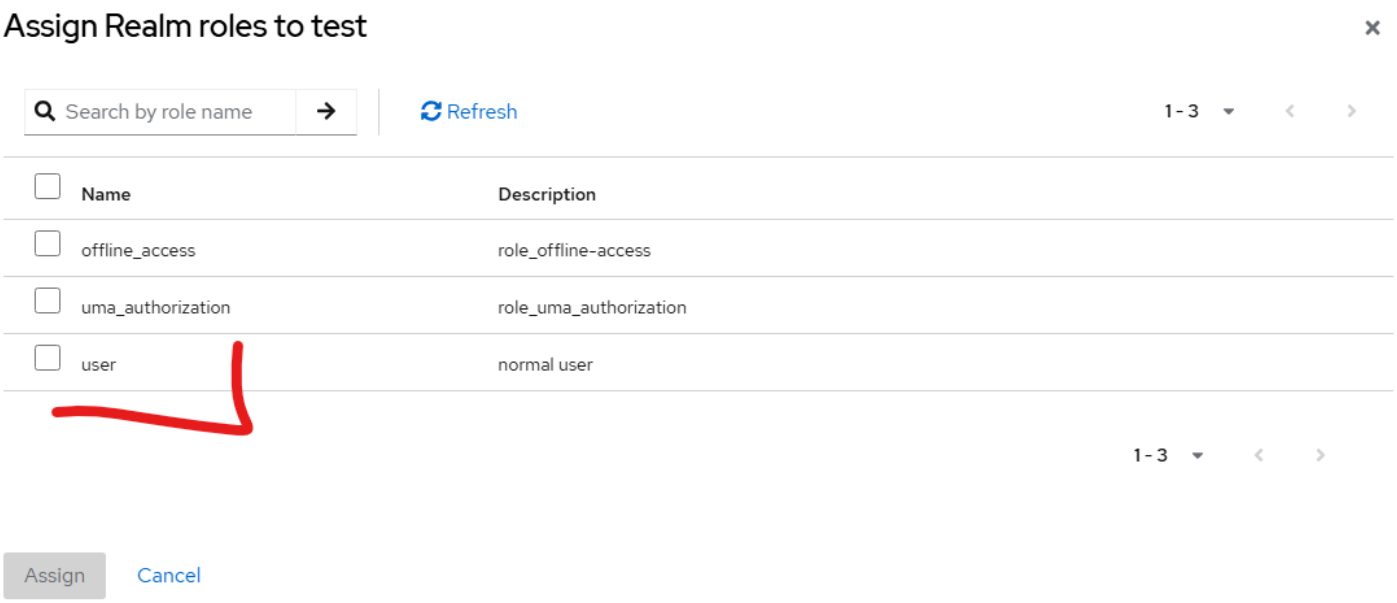
Assign role:

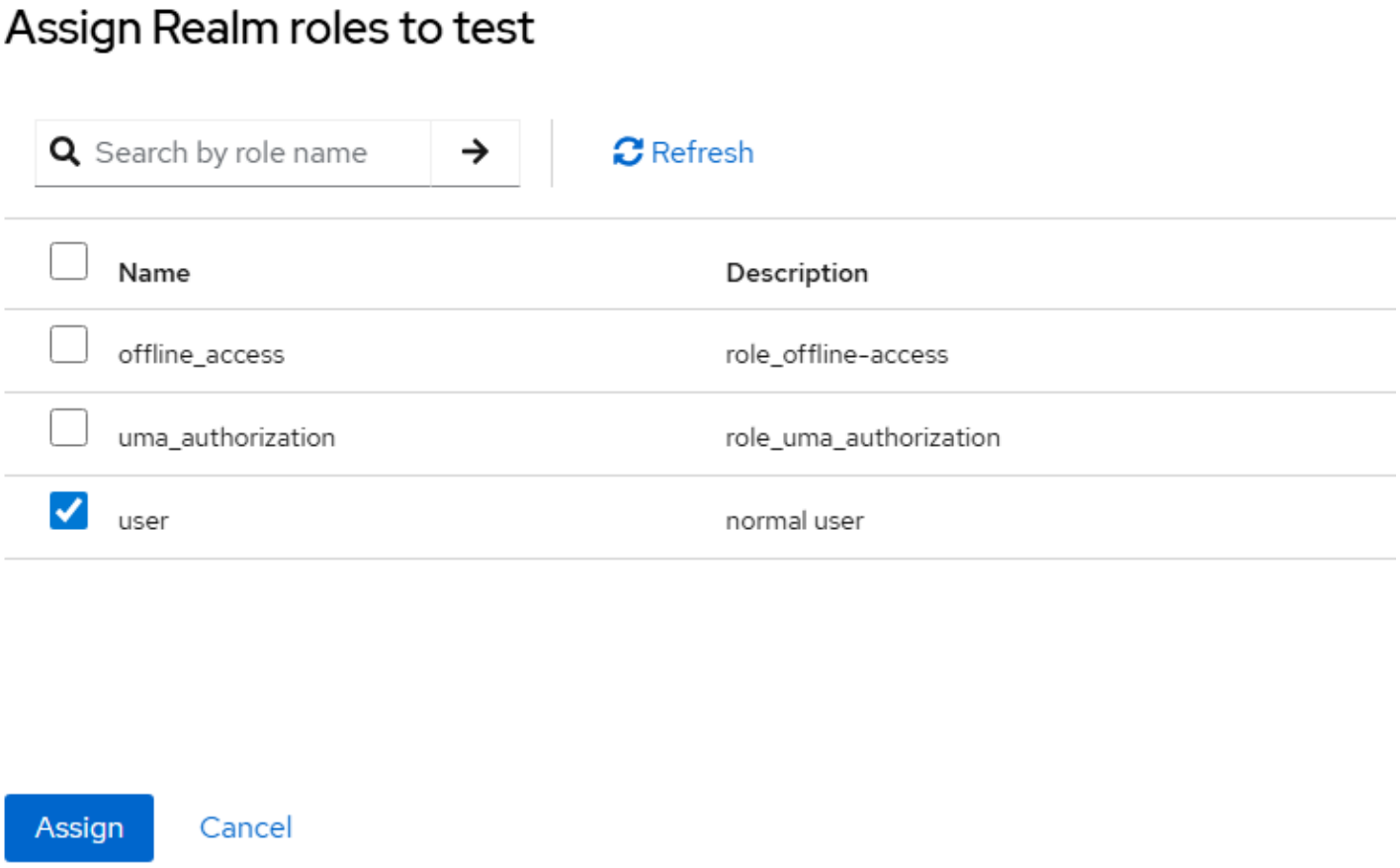


Crete role:









We can assign new role to it!

Default user:

Assign Client roles to user

Search | Refresh | 1 - 20

Name	Client ID	Description
delete-account	account	role_delete-account
manage-account	account	role_manage-account
manage-account-links	account	role_manage-account-links
manage-consent	account	role_manage-consent
view-applications	account	role_view-applications
view-consent	account	role_view-consent
view-groups	account	role_view-groups
view-profile	account	role_view-profile
read-token	broker	role_read-token
create-client	realm-management	role_create-client
impersonation	realm-management	role_impersonation
manage-authorization	realm-management	role_manage-authorization
manage-clients	realm-management	role_manage-clients

photo-app-webclient OpenID Connect

Clients are applications and services that can request authentication of a user.

Settings | Keys | Credentials | Roles | Client scopes | Sessions | Advanced | Events

Setup | Evaluate

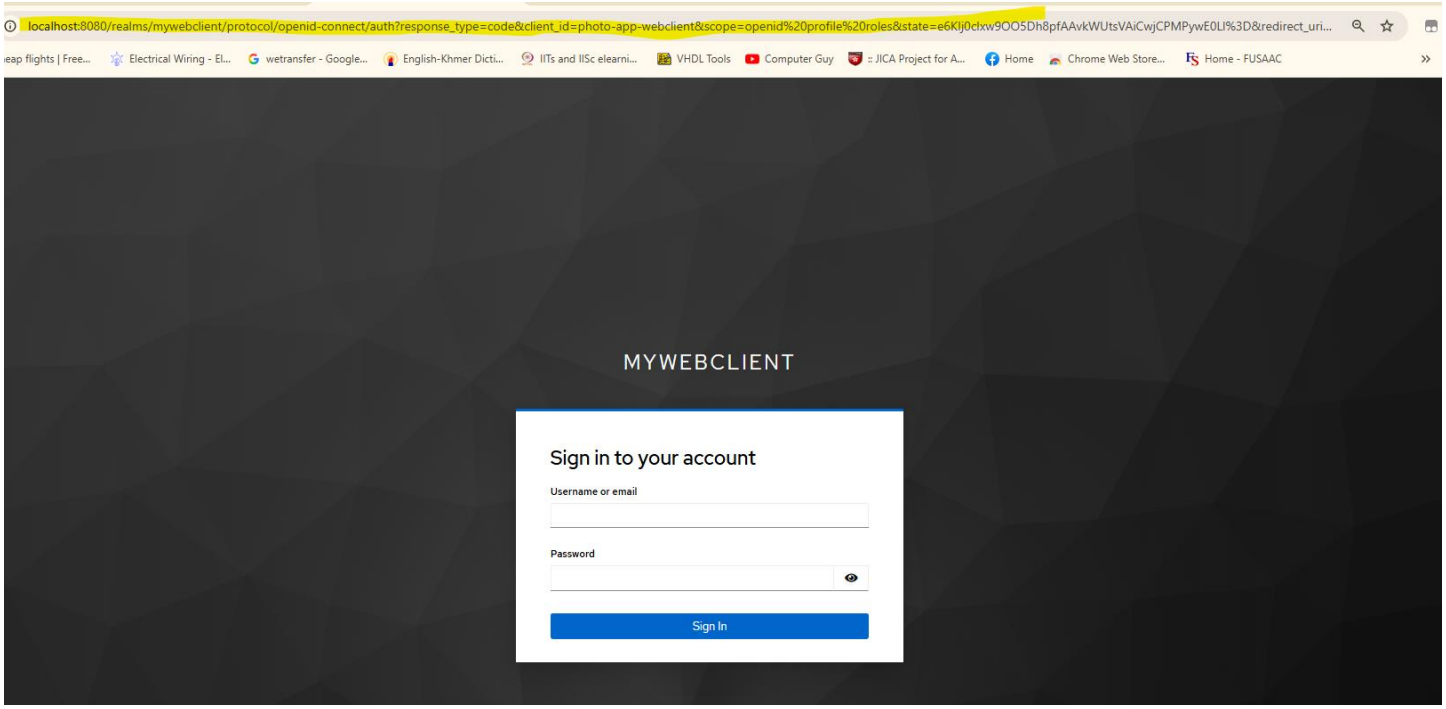
Name | Search by name | Add client scope | Change type to | Refresh

Assigned client scope	Assigned type	Description
photo-app-webclient-dedicated	None	Dedicated scope and mappers for this client
acr	Default	OpenID Connect scope for add acr (authentication context class reference) to the token
address	Optional	OpenID Connect built-in scope: address
basic	Default	OpenID Connect scope for add all basic claims to the token
email	Default	OpenID Connect built-in scope: email
microprofile-jwt	Optional	Microprofile - JWT built-in scope
offline_access	Optional	OpenID Connect built-in scope: offline_access
organization	Optional	Additional claims about the organization a subject belongs to
phone	Optional	OpenID Connect built-in scope: phone
profile	Default	OpenID Connect built-in scope: profile
roles	Default	OpenID Connect scope for add user roles to the access token
web-origins	Default	OpenID Connect scope for add allowed web origins to the access token

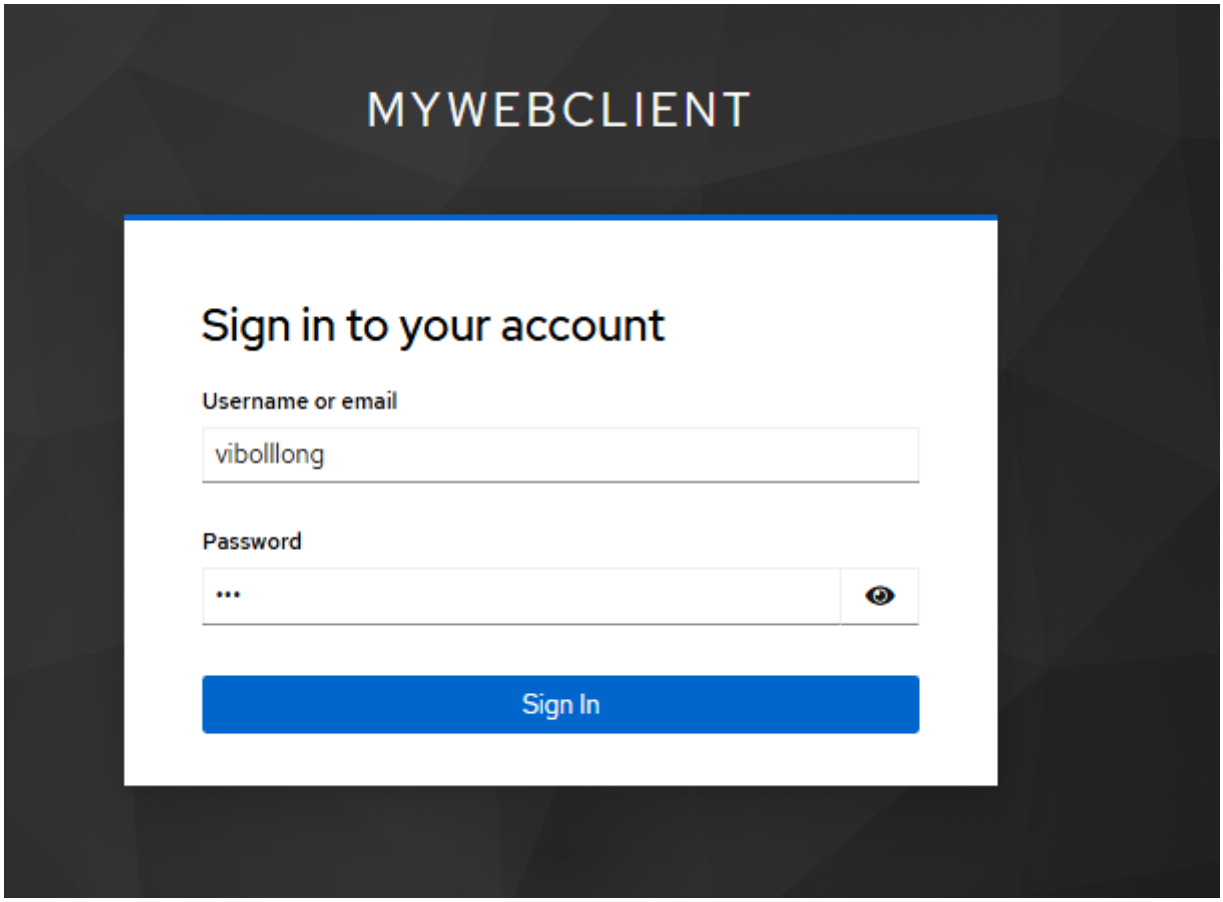
Testing With Login

```
@Controller
public class AlbumsController {

    @GetMapping("/albums")
    public String getAlbums(Model model, @AuthenticationPrincipal OidcUser principal) {

        System.out.println("Principal = " + principal);


        OidcIdToken idToken = principal.getIdToken();
        String idTokenValue = idToken.getTokenValue();

        System.out.println("idTokenValue = " + idTokenValue);
```

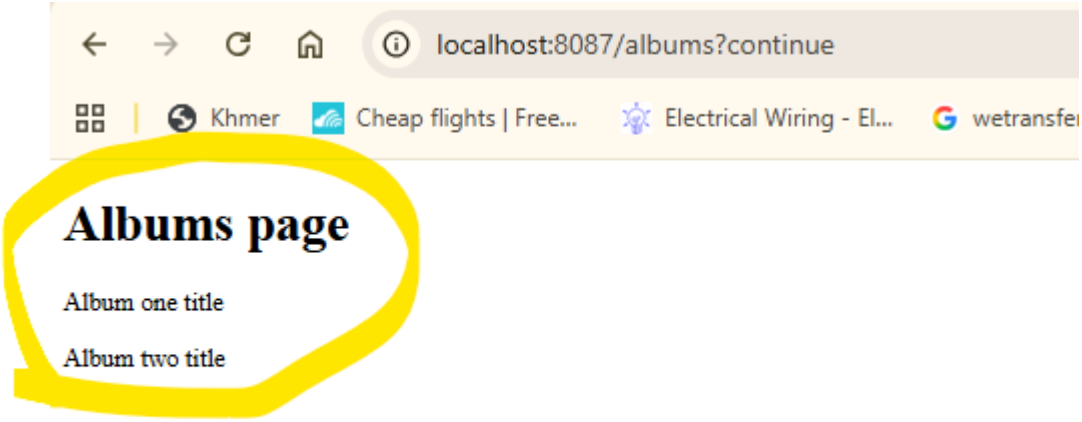
➔ We check the user login Token by creating object from OidcUser



ចំណាំ វានឹងចូលទៅកាន់ Keyload login page!



⇨ After successfully logging in it will directly to our Web MVC



ចំណាំ បើវាអត់ដើរពេល login to :localhost:8087/login : អានឹងវាចូលទៅកាន់ Spring security ទេ

Token id:

```
Spring DispatcherServlet 'dispatcherServlet'
2026-03-05T13:49:15.633+07:00  INFO 28500 --- [PhotoAppWebClient] [nio-8087-exec-1] o.s.web.servlet.DispatcherServlet        : Initializing
Servlet 'dispatcherServlet'
2026-03-05T13:49:15.634+07:00  INFO 28500 --- [PhotoAppWebClient] [nio-8087-exec-1] o.s.web.servlet.DispatcherServlet        : Completed
initialization in 1 ms
Principal = Name: [vibollong], Granted Authorities: [[OIDC_USER, SCOPE_email, SCOPE_openid, SCOPE_profile]], User Attributes: [{at_hash=Hcq3JR-
ao1Rqv1UUVSjihA, sub=2256479e-46c4-4472-93ec-8e1feb81f30a, email_verified=true, iss=http://localhost:8080/realms/mywebclient, typ=ID,
preferred_username=vibollong, given_name=vibol, nonce=hwpP6AM4FczGgks6cix0J0pTE0awUiYs92XTmZ0lhiY, sid=vaFHYvEGgbo6hsmcOBKBNqMi, aud=[photo-app-
webclient], acr=1, azp=photo-app-webclient, auth_time=2026-03-05T06:51:35Z, name=vibol long, exp=2026-03-05T16:51:35Z, family_name=long,
iat=2026-03-05T06:51:35Z, email=vibollong@gmail.com, jti=715057b2-ab4a-57e4-cea6-e155e79dd8ad}]
idTokenValue =
```


eyJhbGciOiJSUzI1NiIsInR5cCIgOiAiSldUIiwia2lkIiA6ICJyZlNWblV3ZzNXVWZib2JxOWxuYWprY1N0ZldPY2dmQkFuNG1iRGk4TmdFIn0.eyJleHAiOjE3NzI3Mjk0OTUsImlhdCI6
MTc3MjY5MzQ5NSwiYXV0aF90aW1lIjoxNzcyNjkzNDk1LCJqdGkiOiI3MTUwNTdiMi1hYjRhLTU3ZTQtY2VhNi1lMTU1ZTc5ZGQ4YWQiLCJpc3MiOiJodHRwOi8vbG9jYWxob3N0OjgwODAv
cmVhbG1zL215d2ViY2xpZW50IiwiYXVkIjoicGhvdG8tYXBwLXdlYmNsaWVudCIsInN1YiI6IjIyNTY0NzllLTQ2YzQtNDQ3Mi05M2VjLThlMWZlYjgxZjMwYSIsInR5cCI6IklEIiwiYXpw
IjoicGhvdG8tYXBwLXdlYmNsaWVudCIsIm5vbmNlIjoiaHdwUDZBTTRGY3pHZ2tzNmNpeDBKMHBURTBhd1VpWXM5MlhUbVowbGhpWSIsInNpZCI6InZhRkhZdkVHZ2JvNmhzbWNPQktCTnFN
aSIsImF0X2hhc2giOiJIY3EzSlItYW8xUnF2MVVVVlNqaWhBIiwiYWNyIjoiMSIsImVtYWlsX3ZlcmlmaWVkIjp0cnVlLCJuYW1lIjoidmlib2wgbG9uZyIsInByZWZlcnJlZF91c2VybmFt
ZSI6InZpYm9sbG9uZyIsImdpdmVuX25hbWUiOiJ2aWJvbCIsImZhbWlseV9uYW1lIjoibG9uZyIsImVtYWlsIjoidmlib2xsb25nQGdtYWlsLmNvbSJ9.YNiWpMxoXbfd9IRE1ybF7XIqpXb
dl7Df0_MhI7MzZK641sgVnzwid04ivTggKNSlGclE_M80qnI8PdcDCW7OpnWi0jm_9rhR8i9ESyYT7wNMA2J178P2M4FN9TwddQ7Sb9T265YtOlMM1rQiCS-
uHYj5CxjgfsSpGtKexN2xI9ArhIEyjGVFAsIYf3HkzV7oEqhuIF_329sCDAgXa1YggpdudHw_hZd66MWfE8PCVSY4bDu5Xy8jwSEF-
6qGkJojPv5tP7zvbUl7MZZ6sRx4CiTx2ixtbdTipvHqcOQcPhhxflk6QnF_sGy5qCtWW5ydf5m0ik7rUnqjow9e-ZMzGQ

DECODED PAYLOAD

JSON CLAIMS TABLE COPY


```
{
  "exp": 1772730307,
  "iat": 1772694307,
  "jti": "onrtro:4f06bc34-c2c0-bb66-227e-8fbf61a48aaa",
  "iss": "http://localhost:8080/realms/mywebclient",
  "aud": [
    "realm-management",
    "broker",
    "account"
  ],
  "sub": "2256479e-46c4-4472-93ec-8e1feb81f30a",
  "typ": "Bearer",
  "azp": "photo-app-webclient",
  "sid": "mGq-RLAwZG8MNhasp9o0X6ZH",
  "acr": "1",
  "allowed-origins": [
    ""
  ],
  "realm_access": {
    "roles": [
      "offline_access",
      "default-roles-mywebclient",
      "uma_authorization",
      "user"
    ]
  },
  "resource_access": {
    "realm-management": {
```